

Q/CUP

中国银联股份有限公司企业标准

Q/CUP 046.8—2014

中国银联 IC 卡技术规范——辅助规范 第 8 部分：金融 IC 卡多应用通用安全指南

China UnionPay integrated circuit card specifications
—auxiliary specifications

Part 8: General Security Guide of Financial IC Card Multiple Applications

2014-11-30 发布

2014-11-30 实施

中国银联股份有限公司 发布

中国银联股份有限公司（以下简称“中国银联”）对该规范文档保留全部知识产权权利，包括但不限于版权、专利、商标、商业秘密等。任何人对该规范文档的任何使用都要受限于在中国银联成员机构服务平台（<http://member.unionpay.com/>）与中国银联签署的协议之规定。中国银联不对该规范文档的错误或疏漏以及由此导致的任何损失负任何责任。中国银联针对该规范文档放弃所有明示或暗示的保证，包括但不限于不侵犯第三方知识产权。

未经中国银联书面同意，您不得将该规范文档用于与中国银联合作事项之外的用途和目的。未经中国银联书面同意，不得下载、转发、公开或以其它任何形式向第三方提供该规范文档。如果您通过非法渠道获得该规范文档，请立即删除，并通过合法渠道向中国银联申请。

中国银联对该规范文档或与其相关的文档是否涉及第三方的知识产权（如加密算法可能在某些国家受专利保护）不做任何声明和担保，中国银联对于该规范文档的使用是否侵犯第三方权利不承担任何责任，包括但不限于对该规范文档的部分或全部使用。

目 次

目 次.....	2
前 言.....	4
1 范围	5
2 规范性引用文件	5
3 术语及定义	5
4 符号和缩略语	6
5 多应用金融智能卡管理模式	6
6 多应用金融智能卡总体安全要求	8
7 多应用金融智能卡应用管理安全架构	9
8 多应用金融智能卡安全要求	19
8.1 多应用金融智能卡安全环境.....	19
8.2 安全威胁攻击.....	19
8.3 安全目标	20
8.4 安全要求	21

中国银联
版权所有

前 言

本指南对金融智能卡加载其他行业应用时应满足的安全条件提出了必要的要求,包括金融智能卡的管理模式、卡片总体安全要求、卡片应用安全要求以及卡片安全要求。

本标准由中国银联股份有限公司提出。

本标准由中国银联股份有限公司制定。

本标准起草单位:中国银联股份有限公司、国民技术、复旦微电子、华大电子、华虹微电子、东信和平。

本标准主要起草人:。

中国银联
版权所有

中国银联 IC 卡技术规范——辅助规范

第 2 部分：金融 IC 卡多应用通用安全指南

1 范围

本标准描述了金融智能卡加载多应用通用安全要求，作为评估金融智能卡加载其他行业应用在产品和系统安全特性的基础准则，本规范包括卡片管理模式、卡片的总体安全要求、应用管理安全架构以及卡片硬件的安全。并明确了安全域关系、数据、安全信道、授权管理内容，为智能卡加载金融应用与其他行业应用的开放共享、安全管理提供了基础标准。

2 规范性引用文件

下列文件中的条款通过本标准的引用而成为本标准的条款。凡是注日期的引用文件，其随后所有的修改单（不包括勘误的内容）或修订版均不适用于本标准，然而，鼓励根据本标准达成协议的各方研究是否可使用这些文件的最新版本。凡是不注日期的引用文件，其最新版本适用于本标准。

- GB/T 16649 识别卡 带触点的集成电路卡
- Q/CUP 040.1—2011 银联卡芯片安全规范
- JR/T 0025 中国金融集成电路（IC）卡规范

3 术语及定义

金融智能卡 Smart Card (SC)

集成了安全运算单元和安全存储的集成电路（IC）卡片。

智能卡支付 Smart Card Payment

通过存储金融数据的智能卡进行安全认证的支付业务。

应用 Application

智能卡和终端之间的应用协议和相关的数据集。

应用协议报文 APDU (Application Protocol Data Unit)

协议数据单元（PDU），是指对等层次之间传递的数据单位。应用协议数据单元（APDU）是智能卡与读卡器之间传送的信息单元。

安全芯片 Secure Element

组成智能 IC 卡的主要器件，主要负责交易关键数据的安全存储和运算功能。

闪存 Flash Memory

一种电子式可清除程序化的只读存储器，允许在操作中被多次擦写。主要用于一般性数据存储，以及电脑和其他数字产品间传输数据的交换，如存储卡与闪存卡。闪存是一种特殊的、以宏块抹写的EEPROM。

随机存储器 Random access memory

随机存储器，存储单元的内容可随意取出或存入，且存取的速度与存储单元的位置无关。这种存储器在断电时将丢失其存储内容，主要用于存储短时间使用的程序。

密钥 Key

加密转换中控制操作的一组符号。

数字证书 Digital Certificate

由认证中心签名的不可伪造的某个实体的公钥信息。

数字签名 Digital Signature

对数据的一种非对称加密变换。该变换可以使数据接收方确认数据的来源和完整性，保护数据发送方发出和接收方收到的数据不被篡改。

应用拥有者 Application Owner

组织开发者开发应用，并持续维护应用，对应用拥有控制权的主体。

应用提供者 Application Provider

实现应用并为应用安装提供下载文件或密钥的主体。

机密性 Confidentiality

信息不能泄漏给未授权实体。

完整性 Integrity

信息没有遭受未授权方式的更改或是破坏。

安全属性 Security Attribute

主体、用户、客体、信息等资源性的用于定义安全功能需求并实施安全策略的特征参数。

卡片发行者 Card Issuer

将卡片发行到用户手中的机构。

卡片制造者 Card Manufacturer

依据卡片发行者的利益制造卡片的实体。

生命周期 Life Cycle

智能卡或应用所有可能状态的集合。

锁定 Locked

应用状态锁定，仅有拥有管理权限的授权者才可以解锁状态。

解锁 Unlocked

锁定的状态通过授权密钥进行解锁，恢复到可用状态。

终止 Terminated

最终的生命状态，卡片或应用不再可用。

密钥管理机构 Key Management System

依据卡片发行者的利益提供平台或应用相关的密钥管理。

4 符号和缩略语

AID	Application Identifier	应用标识符
AP	Application Processor	应用处理芯片
APDU	Application Protocol Data Unit	应用协议数据单元
COS	Chip Operation System	卡片操作系统
KEK	Key encryption key	密钥加密密钥

5 多应用金融智能卡管理模式

5.1 卡片生命周期

智能卡开发和制造的几个阶段，可以分为以下几个阶段：

- 开发阶段：智能卡嵌入式软件和应用的开发；集成电路的设计、开发和掩膜制造。
- 集成电路的生产阶段：智能卡芯片的制造、测试、装配阶段。
- 智能卡生产阶段：智能卡的封装、印刷、加工以及个人化的准备阶段。
- 智能卡发行和个人化阶段：下载特定的用户数据到智能卡的存储区中。
- 智能卡最终用户阶段：该阶段包括（多）应用的下载和管理，卡片的锁定、解锁、

终止。

多应用金融智能卡开发和制造的阶段,主要包括智能卡的个人化阶段以及智能卡的最终使用阶段。多应用金融智能卡完成个人化,意味着多应用金融智能卡已经可以正常工作,卡片内已配置卡片发行者的应用和功能,所有的私密数据和安全密钥都已下载到卡内,卡片进入一个安全状态;在此安全状态下,卡片可以交付给最终用户使用,可以安装其他应用程序,包括行业应用,银行金融应用和商业应用提供方应用。该卡片上可运行着若干来自发卡方的应用,若干来自应用提供方的应用,以及若干提供全局服务的应用。

5.2 多应用金融智能卡生态圈

多应用金融智能卡是指除加载金融应用,实现借贷记功能之外,还同时加载了其他行业应用的智能卡,比如社保、交通、电信等应用。该类型智能卡生存在一个复杂的生态圈中,多个主体为智能卡的开发、生产、使用等不同阶段营造适宜的生态环境。智能卡生态圈由芯片制造者、卡片制造者、卡片发行者、密钥管理机构、卡片使能者、应用提供者、应用拥有者、用户等主体根据不同的智能卡管理模式互相制约协调,维系着完整的生态链。

对于 Java 卡,其生命周期的管理可以按照“《中国银联移动支付技术规范》第2卷第2部分”的要求来操作;对于 Native 卡片,其生命周期如下图所示:

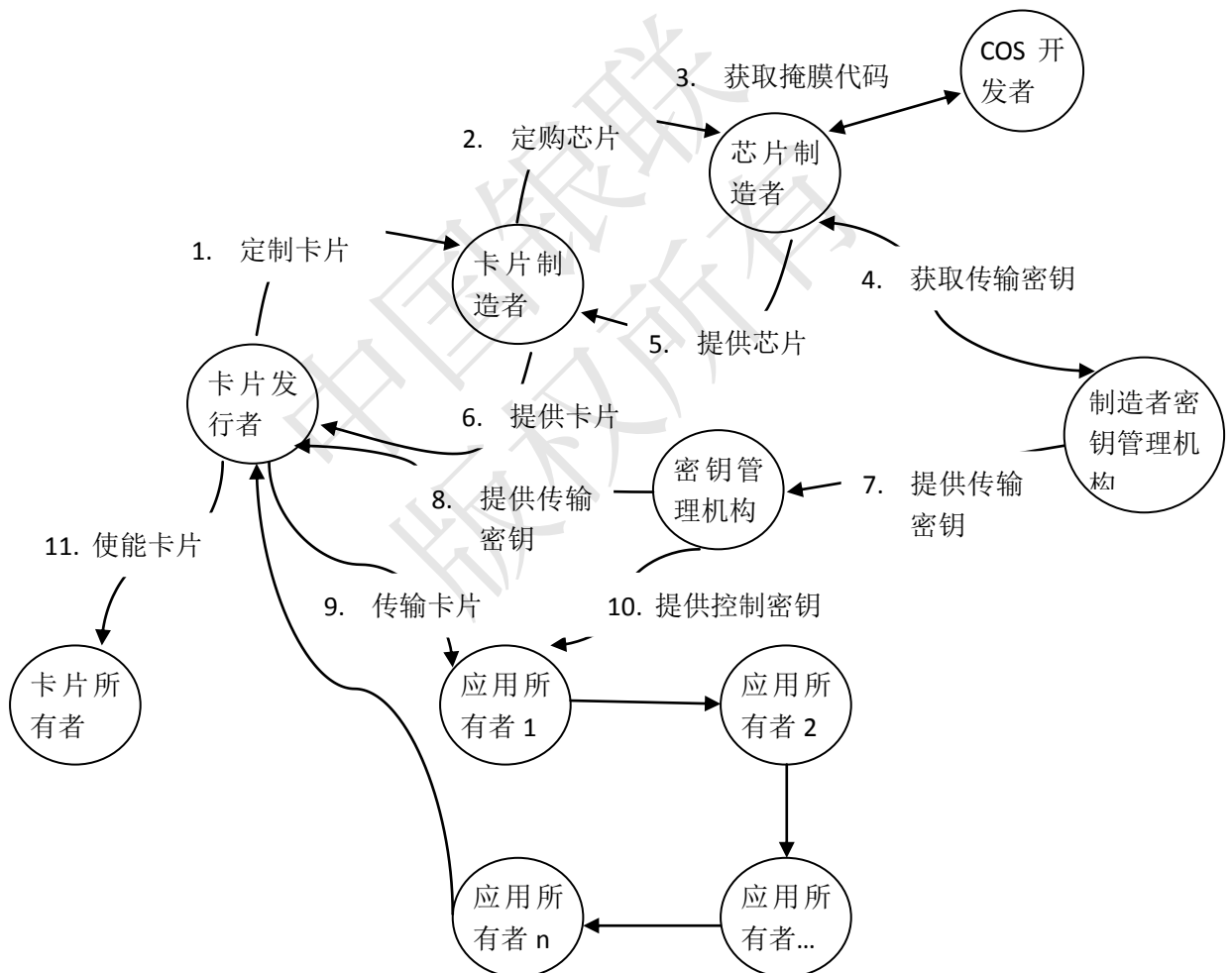


图 1 多应用金融智能卡片生命周期

- (1) 卡片发行者向卡片制造者发起卡片订制需求。
- (2) 收到订制需求后,卡片制造者向芯片制造者订购芯片。
- (3) 芯片制造者为了制造芯片需要从 COS 开发者处获取掩膜代码。

(4) 芯片制造者所需的传输密钥由制造者密钥管理机构提供初始传输密钥。制造者密钥管理机构在向芯片制造者提供初始传输密钥的同时，也向卡片使能者提供初始传输密钥。

(5) 卡片制造者从芯片制造者获得芯片后制造卡片。

(6) 制造后的卡片由卡片制造者供应给卡片发行者。

(7) 在密钥管理机构提供卡片使能数据及密钥前需向制造者密钥管理机构获取卡片的初始传输密钥。

(8) 卡片发行者在获得卡片后，需要向密钥管理机构申请卡片传输密钥。

(9) 接着卡片传送到应用所有者，由应用所有者根据使用从密钥管理机构获得密钥认证后获得权限，创建自己的应用，个人化自己应用的数据。各应用所有者所发行的各个应用，彼此之间没有必然的先后顺序依赖关系。

(10) 应用所有者从密钥管理机构获得权限密钥。

(11) 卡片发行者使能卡片后发给卡片所有者。

5.2.1 银行为发卡主体

在以银行为发卡主体的管理模式下，多应用金融智能卡的卡片主控密钥由卡片发行机构管理，卡片个人化、卡片应用的下载、安装和删除以及卡片密钥管理等都受卡片发行机构控制约束。该管理模式可以通过管理授权、代理委托等扩展形式，形成更多更具体的满足现实需求的管理模式。

5.2.2 以多方机构平等合作的管理模式

在以多方平等合作的管理模式下，不同的机构、行业可以通过合作的方式平等的管理多应用金融智能卡。合作各方可以在安全条件下自由地对多应用金融智能卡进行个人化、应用的下载/安装、密钥管理等操作，多应用金融智能卡的安全则由所有的合作机构共同负责。该管理模式可以根据具体情况形成更多更具体的管理模式，如不同的机构间是绝对平等还是相对平等，不同机构对卡内资源的配额是否均等。

6 多应用金融智能卡总体安全要求

6.1 智能卡操作系统软件开发阶段

在卡片开发阶段必须保证智能卡操作系统软件代码从开发者到智能卡制造者之间传输的保密性、完整性。由于智能卡操作系统软件开发者、智能卡制造者都是从密钥管理机构获取传输密钥，因此密钥管理机构还需要保证以安全的方式进行密钥的生成、维护和传递。智能卡操作系统软件代码开发者、智能卡制造者以及密钥管理机构都必须保证代码、密钥的传输、存储安全。

智能卡操作系统软件采用平台和应用架构，平台和应用独立开发时，则需要保证应用开发过程的安全性(如:应用代码不可非法泄露)，应用代码存储、传输的安全性；以及保证应用本身的安全性，即应用是否依照平台提供的安全API进行编写，应用代码在传输之前是否进行了签名供接收方校验。应用提供者与应用下载机构之间在传输应用代码及数据时也需要建立安全通道保证数据传输的机密性。且应用开发者不得在应用中留有规范要求之外的后门指令。

6.2 智能卡发行阶段

发卡阶段，根据集中或分布等发卡模式的不同，发卡机构可以有唯一或多个，发卡机构须维护用户数据机密性，如用户账号、密码等数据。集中发卡时，唯一的发卡机构须保证各

应用的数据和密钥在传输和写卡时相互隔离。分布发卡时，发卡机构只能写入自身应用的数据和密钥，不能修改、破坏卡内其他应用的数据和密钥。

发卡机构在和其它机构进行数据传输时都必须通过安全通道完成安全数据交换，如发卡机构从密钥管理机构获取卡片使能数据和密钥或是发卡机构传送卡片密钥到卡片使能机构时都需保证通道的安全性。

卡片应提供传输数据安全保护机制，以保证发卡时数据和密钥传输的机密性。卡片应提供安全访问控制，禁止未授权而创建、修改、删除应用数据和密钥。

6.3 智能卡使用阶段

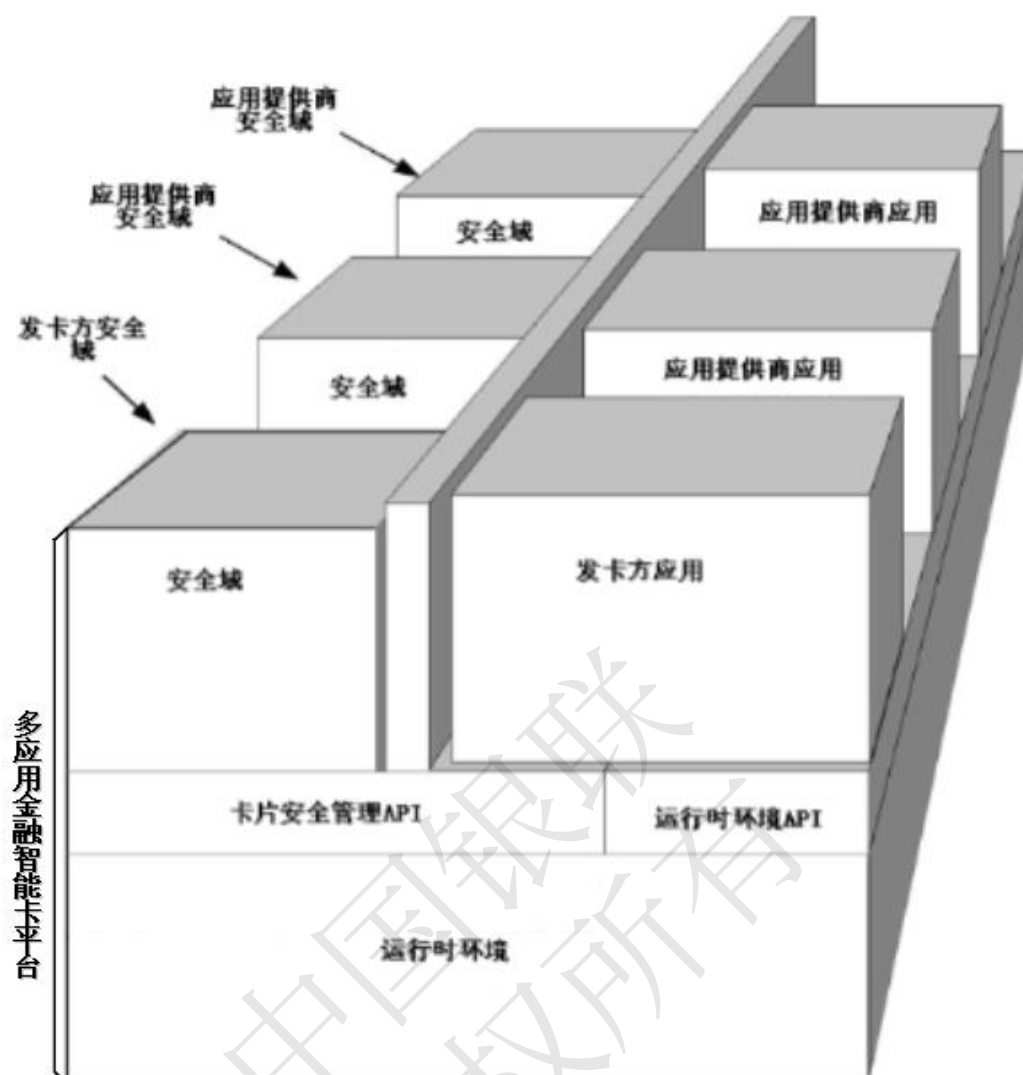
智能卡的使用阶段包括应用的增加、删除以及应用的运行。应用的安全增加、删除需要应用下载机构提供安全的通讯机制来实现。应用本身的安全运行需要遵循各自应用的规范，卡片提供安全机制保证运行安全，同时提供安全访问控制，禁止未授权而访问、修改应用数据和密钥。

7 多应用金融智能卡应用管理安全架构

7.1 多应用安全架构

多应用金融智能卡应用管理安全架构提供可供多方参与的多应用安全管理框架，保证不同应用提供商在金融智能卡上的应用程序和应用数据的安全管理。

多应用金融智能卡要求卡片中的多个应用在一个安全的卡平台上实现，其安全架构组成如下：运行时环境、运行时环境 API、卡片管理安全接口、安全域以及各应用等。其中，运行时环境、运行时环境 API、卡片管理安全接口以及至少一个安全域（发行者安全域）构成了多应用金融智能卡平台，为多个应用提供独立于硬件平台的安全框架，并负责智能卡的安全防护，以防止多应用金融智能卡内部的代码和数据遭受外部攻击。



7.1.1 运行时环境

安全的运行时环境控制着对内存等硬件资源的分配和管理,为各应用提供安全的存储和执行空间,使得各应用的代码和数据相互保持隔离,或者有限制地进行安全信息交换。当存储空间被释放再利用时,必须保证该存储空间的内容不可泄露。当卡片操作过程中发生异常掉电或者插拔时,需保证存储器的恢复过程是安全的。

为确保不同的应用间不会互相影响,对各应用的代码和数据要求强制实现应用防火墙,未经允许(开放)的数据和程序代码将无法被其它应用访问。严格遵守应用各自的从属关系和访问条件,在应用下载前检查各应用不同的限制和依赖关系;在应用运行时也严格限定当前的上下文环境和资源访问边界。

运行时环境必须保证其安全机制不可被绕开、停用、破坏或其他方式的规避。

运行时环境还提供一套与硬件芯片以及平台提供商无关的应用程序接口及相关服务,供应用提供商进行应用开发。

7.1.2 运行时环境 API

各应用通过运行时环境 API 访问运行时环境提供的各类服务以及硬件资源,如通信接口、内存、密码服务等。

7.1.3 卡片管理安全接口

卡片管理安全接口以统一 API 的形式为应用提供各类服务，如个人化服务、安全服务、卡内容管理服务等。其中卡内容管理包括卡内容的下载、安装、删除以及应用的生命周期状态变更等。必须保证其安全机制不可被绕开、停用、破坏或其他方式的规避。

7.1.4 安全域

安全域是发卡方及应用提供商在多应用金融智能卡上的代表，为各自的应用提供安全服务：如密钥处理、加密、解密、为应用的所有者提供数字签名及校验，使得发卡方及各应用提供商能使用相互独立的密钥集合，独立管理着各自的应用及数据。

每一个安全域都应该实现安全通道协议，以保证多应用金融智能卡卡外实体与多应用金融智能卡卡上安全域的通信安全。

安全域可以为其应用在预个人化时提供加密保护服务。

安全域也为各应用提供统一外部接口以访问安全域提供的服务，使得多应用金融智能卡卡外管理系统能统一管理不同厂商实现的多应用金融智能卡。

7.1.5 应用

根据不同运营商的规定，应用可能可以在多应用金融智能卡生命周期的不同阶段进行安装，也可能会由于其他行业的要求而不允许在某些生命周期阶段（如卡片发行后）下载安装。被安装的应用可以是完全隔离的，也可以有条件的进行可控的互操作。

对于那些在多应用金融智能卡发行时已安装到卡上的应用称之为预装应用；那些在多应用金融智能卡发行后才安装到卡上的应用称之为动态加载应用。

7.1.6 密码服务

多应用金融智能卡应用管理安全架构应能够提供相关密码功能，如数字签名的产生、对称加解密、非对称加解密等，利用这些密码功能可以为应用提供如下密码服务：

1. 完整性认证
2. 机密性
3. 安全报文

7.2 密码服务

7.2.1 完整性认证

完整性认证指的是：发送方利用某些方法如密码学方法，为相关报文或者数据块（应用代码或者应用数据）产生一个附件数值，通过此附件数值接收方可以对源数据进行校验，验证特定的报文或者数据块（应用代码或者应用数据）是否在传输过程中被篡改，即是否完整。

完整性认证所采用的密码学方法有 Hash、数字签名、DES 操作生成的 MAC 等方式。

7.2.2 机密性

机密性指的是：一个发送方对报文数据域或者敏感数据区进行机密处理，以保证传送的数据，对被未经过认证的实体来说是不可见的；接收方需经解密才能得到明文数据。

7.2.3 安全报文

安全报文指的是：允许一个发送实体在传送报文前，为该报文的敏感数据进行加密和/

或增加完整性认证机制，并将符合机密性和/或完整性认证机制的数据组成 APDU 报文发送给一个接收实体。

安全报文可以通过以下的方式来实施：

1. 对发送给卡片的一条 APDU 命令增加完整性认证机制，或者对发送给卡片的一条 APDU 命令同时增加命令报文的机密性和完整性认证机制。
2. 在一个安全通道会话过程中，对发送给卡片的一系列 APDU 命令（APDU 命令序列）增加完整性认证机制。
3. 可选的，对卡片发送的一条 APDU 应答报文增加机密性和/或完整性认证机制；在一个安全通道会话过程中，对发送给卡片的一系列 APDU 应答（APDU 应答序列）增加完整性认证机制。这取决于所采用的安全通道协议。

7.3 安全通信机制

利用上述密码服务，多应用金融智能卡应用管理安全架构可以搭建安全的通信环境，使得多应用金融智能卡能与卡外实体进行安全的信息交换。生命周期的不同阶段决定了多应用金融智能卡与卡外实体的安全通信等级。

7.3.1 实体认证

多应用金融智能卡与卡外实体的单向或双向认证，保证进行数据交换的发送实体和/或接收实体为可信任实体。

7.3.2 完整性认证

一个接收实体（多应用金融智能卡或卡外实体）通过密码学方法保证来自一个发送实体（多应用金融智能卡或卡外实体）的数据确实来自自己认证的实体，且该数据未被做任何篡改。

7.3.3 密文传输

一个发送实体（多应用金融智能卡或卡外实体）发送给一个接收实体（多应用金融智能卡或卡外实体）的数据是以密文的方式进行传输的，对被未经过认证的实体来说是不可见的。

7.4 生命周期模型

生命周期模型包含以下组件：

1. 卡片
2. 可执行下载文件/可执行模块
3. 应用及安全域

由于多应用金融智能卡可能预置某些应用，也可能在卡片发行后动态下载某些应用，因此，各组件的生命周期状态模型相对对立。如可执行下载文件/可执行模块组件的生命周期状态可能存在于卡片发行之前的准备阶段、初始完成阶段，也可能存在于发行之后的安全状态阶段；类似的，应用的生命周期状态也可能存在于卡片发行之前的准备阶段、初始完成阶段，也可能存在于发行之后的安全状态阶段。

7.4.1 卡片的生命周期

卡片的生命周期描述详见 5.1 节。

7.4.2 可执行下载文件/可执行模块的生命周期

可执行下载文件/可执行模块，是芯片上一个或多个可执行代码（可执行模块）实际存

储形式，其生命周期状态只有一种，如下：

1. “已下载”。

对于存储在易失内存中的 EXECUTABLE LOAD FILES/EXECUTABLE L LOAD MODULES，物理空间可被释放，且能被再利用，比如存储在 EEPROM 或 FLASH 中可被删除且空间可再利用；对于存储在永久性内存中的 EXECUTABLE LOAD FILES/EXECUTABLE L LOAD MODULES，不可被删除，删除的只是与之相关的记录信息，如存储在 ROM 中的不可被删除。无论存储在哪种存储介质中，都会删除注册表中对应的注册记录信息。

7.4.2.1 可执行下载文件“已下载”状态

一个下载文件通过 APDU 命令，安全、完整地传送并存储到卡上，同时与相关安全域相关联，即处于已下载状态。

7.4.2.2 可执行下载文件的删除

如果多应用金融智能卡接收到删除可执行下载文件的请求，则该可执行下载文件/可执行模块所有相关联信息均需被删除，多应用金融智能卡不能保留或者泄露任何该可执行下载文件/可执行模块相关记录；同时之前被该可执行下载文件/可执行模块所占用的物理空间也应该被释放以便重新使用。

如果多应用金融智能卡接收到的请求还要求删除每一个由可执行下载文件中的可执行模块实例化出来的应用，则详见 7.4.3.1.4 节“应用的删除”。

7.4.3 应用及安全域的生命周期

一个应用或者安全域的生命周期开始于该应用被实例化。

在应用的安装过程中，当一个应用被实例化的时候，该应用的生命周期状态被设置为初始的“已安装”状态；在应用的安装过程中，当一个应用可被选择的时候，该应用的生命周期状态被设置为“可选择”状态；一旦该应用可被选择，其生命周期将由该应用本身来控制。

应用或者安全域的生命周期状态控制或者切换均需在安全保护的情况下进行；同时卡外实体也可以通过统一的卡片安全管理接口查看相关应用或安全域的生命周期状态。

7.4.3.1 应用生命周期状态

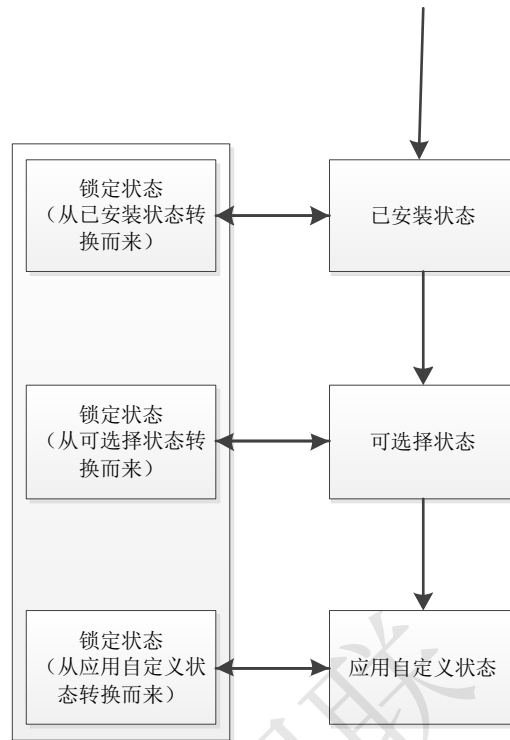
一个应用的生命周期包括以下状态：

1. “已安装”
2. “可选择”
3. “锁定”

除此之外，应用也可以定义其自己特定的生命周期状态，如应用个人化状态。

一旦应用达到了“可选择”状态，其生命周期的后续状态由该应用本身进行管理；只要与上述应用生命周期状态定义没有冲突，应用也可以使用并独自管理自定义的生命周期状态，保证状态切换的安全性。

下图为应用的生命周期状态转换图。



7.4.3.1.1 应用“已安装”状态

应用的“已安装”状态意味着：应用的可执行代码已完成正确的动态链接且所需的存储资源分配已完成，但应用当前还不可被选择。应用的安装过程不应该与应用的个人化结合在一起，应用的个人化应该是一个单独的过程。

7.4.3.1.2 应用“可选择”状态

应用的“可选择”状态意味着：应用可以被选中并接收来自卡外实体的指令。应用的“已安装”状态和“可选择”状态是不可逆的。应用在被设置为“可选择”状态之前，应该已被正确的安装。“可选择”状态的切换，可能包含在应用的安装过程中。

7.4.3.1.3 应用“锁定”状态

应用的“锁定”状态被用于安全管理控制，以防止该应用被选择和执行。

考虑业务或安全的因素，如果检测到与一个特定的应用相关的威胁，应用可能会被设置成“锁定”状态以阻止对该应用进一步的选择、执行等操作。

当应用被解锁时，应恢复到该应用被锁定之前的状态。

7.4.3.2 应用的删除

在应用生命周期的任何状态中，多应用金融智能卡都可能接收到删除应用的请求。

如果多应用金融智能卡接收到删除应用的请求，则该应用所有相关信息均需被删除，多应用金融智能卡不能保留或者泄露任何该应用的相关记录；同时之前被该应用所占用的物理空间也可能被释放以便重新使用。

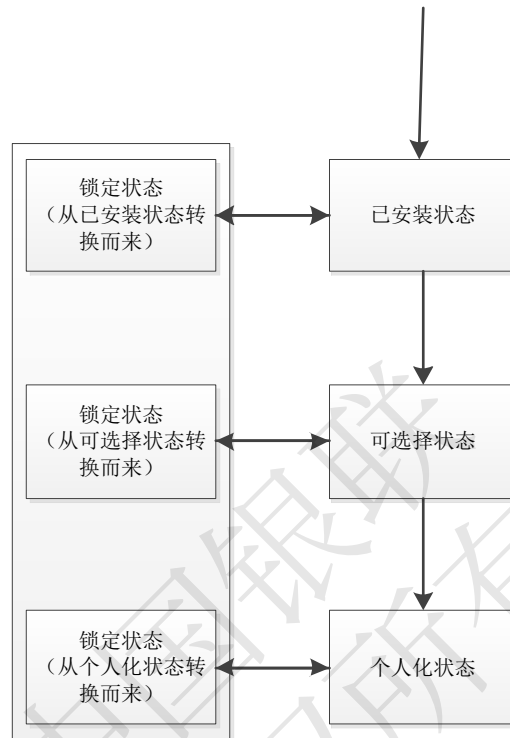
7.4.3.3 安全域生命周期状态

一个安全域的生命周期包括以下状态：

1. “已安装”
2. “可选择”
3. “个人化”
4. “锁定”

安全域不允许出现自定义的私有状态。

下图为安全域的生命周期状态转换图。



7.4.3.3.1 安全域“已安装”状态

安全域的“已安装”状态意味着：安全域的可执行代码已完成在卡片上注册，但该安全域当前还不可被选择，也未与可执行下载文件或者应用相关联，因此该安全域所提供的服务也不可被应用所使用。

7.4.3.3.2 安全域“可选择”状态

安全域的“可选择”状态意味着：安全域可以被选中并接收来自卡外实体的指令（尤其是个人化指令）。在此状态下，由于该安全域密钥尚未安装，也没有与可执行下载文件或者应用相关联，因此该安全域所提供的服务也不可被应用所使用。

安全域的“已安装”状态和“可选择”状态是不可逆的。安全域在被设置为“可选择”状态之前，应该已被正确的安装。“可选择”状态的切换，可能包含在安全域的安装过程中。

7.4.3.3.3 安全域“个人化”状态

安全域的“个人化”状态是统一定义的，它意味着：在此状态下，安全域具备了所有个人化数据以及完整的运行时环境功能所需要的各类密钥；此时，安全域与应用相关联，因此该安全域所提供的服务可被关联的应用所使用。

安全域的“可选择”状态和“个人化”状态是不可逆的。安全域在被设置为“可选择”

状态之前，应该已被正确的安装。

7.4.3.3.4 安全域“锁定”状态

安全域的“锁定”状态被用于安全管理控制，以防止该安全域被选择。

考虑业务或安全的因素，如果检测到与一个特定的安全域相关的威胁，安全域可能会被设置成“锁定”状态以阻止对该安全域进一步的选择；该安全域所提供的服务也禁止访问；且该安全域不能再与任何新的可执行下载文件或者应用相关联。

当安全域被解锁时，应恢复到该安全域被锁定之前的状态。

7.4.3.4 安全域的删除

在安全域生命周期的任何状态中，多应用金融智能卡都可能接收到删除安全域的请求。

如果多应用金融智能卡接收到删除安全域的请求，则该安全域所有相关联信息均需被删除，多应用金融智能卡不能保留或者泄露任何该安全域的相关记录；同时之前被该安全域所占用的物理空间也可能被释放以便重新使用。

7.5 应用安全

多应用金融智能卡允许多个应用安全共存于一张智能卡上，每个应用的代码和数据独立于其他应用的代码和数据。多个应用既可以在多应用金融智能卡发行时预置到卡上，也可以根据业务的需要，在多应用金融智能卡发行后动态加载到卡上。因此，应用既包含预装应用，也包括动态加载应用。

多应用金融智能卡应能防止应用代码及其应用数据未经授权的泄露和修改，如应用软件代码、密钥、PIN 码等。一个应用既不能读、写一段其他未经授权应用的数据，也不能执行未经授权的其他应用的代码。

为了能达到以上目的，多应用金融智能卡应提供以下机制：

1. 对被不同应用所使用的数据实行逻辑隔离（防火墙机制）；
2. 安装之前对代码进行静态分析（代码校验机制）；
3. 在代码校验与安装流程中进行代码完整性的保护；
4. 针对应用使用特定的安全服务：
 - 1) 对密钥、PIN 等敏感数据采用特定的安全管理；
 - 2) 密码学认证机制和加密机制

应用安全主要包括应用代码的安全以及应用数据的安全。

应用代码指的是存储在多应用金融智能卡中，在多应用金融智能卡应用管理安全架构控制下安全运行的所有应用的代码，如金融应用代码、电信应用代码、政务应用代码、交通应用代码、ID 类应用代码、电子表计应用代码等。

应用数据指的是存储在多应用金融智能卡中，在应用运行时，可被安全访问和操作的各类数据，如应用的传输密钥、应用的初始化数据、应用数字证书、应用通信记录、日志文件等。

对敏感类的应用代码和应用数据必须保证其机密性和完整性认证，防止非法操作获得多应用金融智能卡应用代码和应用数据的读写访问权限，导致信息泄露或者造成未经授权的修改。如金融应用中的持卡人 PIN 码、应用传输密码、应用交易时使用的证书等数据。

7.5.1 预装应用

预装应用指的是存储在多应用金融智能卡中，在多应用金融智能卡应用管理安全架构控制下安全运行的所有预装应用的代码及相关数据的总和，如多应用金融智能卡发行时已预

置到卡上的金融应用代码及数据、电信应用代码及数据、政务应用代码及数据、交通应用代码及数据、ID 类应用代码及数据、电子表计应用代码及数据等。

7.5.1.1 应用代码安全

对于发行的多应用金融智能卡而言，预装应用代码为已安装代码，它的安全性首先由应用防火墙机制来保证各应用之间的隔离，防止一个应用未经授权访问任何其他应用的代码，主要着眼于运行时的安全防护。每一个应用程序都有自己独立的运行空间，不同应用之间的运行空间是完全隔离的。应用独立的安全运行保护能够防止应用程序被非法对象干扰或篡改。对应用程序独立的安全运行保护必须实行完全的访问控制，即应用在运行阶段执行方法调用、对象创建、对象删除、数据访问等操作都必须执行访问控制策略，保证应用程序不超出自己的运行环境。

除以上所述的完全隔离之外，防火墙机制也提供可控的应用之间的通信，在必要的时候通过多应用金融智能卡平台提供的服务来进行安全信息交换。

应用代码的安全隔离仅有防火墙机制也是不够的，在应用代码安装上卡片之前，还需要经过代码校验，静态分析代码的正确性、完整性和有效性，在校验成功后与授权校验数据相关联，多应用金融智能卡对该数据校验成功后才能进行应用的下载安装等操作。

7.5.1.2 应用数据安全

对于发行的多应用金融智能卡而言，预装应用为已安装应用，已安装应用数据的安全性首先由应用防火墙机制来保证各应用之间的隔离，防止一个应用未经授权访问任何其他应用的数据，主要着眼于运行时的安全防护。多应用金融智能卡必须保证应用只能通过运行环境以及统一 API 接口访问硬件芯片的存储空间，这样防火墙机制不可被绕开，才能保证应用数据，如文件系统、密钥等安全地存放于各自的存储空间，以防止被故意损坏或者未被授权修改。

除以上所述的完全隔离之外，防火墙机制也提供可控的应用之间的通信，在必要的时候通过多应用金融智能卡平台提供的服务来访问其他应用的数据。

有效完全的防火墙机制还需要配合代码校验机制才能真正达到应用数据安全隔离，阻止应用数据被非法访问或破坏。

对安全敏感数据，还可采用特定的安全管理，并通过机密性和完整性认证等机制进一步保证其安全性。通过数据的安全属性选择不同的完整性认证和加密机制：如通过数据 Hash 值来校验数据的完整性；通过对完整性敏感的数据进行特征值校验如 MAC 校验来保证数据未被篡改；通过对机密性敏感的数据进行加密来保证明文数据不可见。需要进行完整性认证、机密性保护的数据包括 PIN 码、用户校验方法相关安全属性、应用主密钥、传输密钥、机密的算法服务程序等代码或数据。

多应用金融智能卡平台负责安全的存储空间的分配，在应用请求资源时，必须保证存储区先前的信息是无效的，以防止存储区先前的数据的非法泄露。

7.5.2 动态加载应用

动态加载应用指的是存储在多应用金融智能卡中，在多应用金融智能卡应用管理安全架构控制下安全下载、安装及运行的所有在卡片发行后加载的应用代码及相关数据的总和，如根据业务需要，在多应用金融智能卡发行后才动态下载安装到卡上的金融应用代码及数据、电信应用代码及数据、政务应用代码及数据、交通应用代码及数据、ID 类应用代码及数据、电子表计应用代码及数据等。

动态加载应用与预装应用不同，通常在多应用金融智能卡发行后才下载到卡片上，且应用提供方不一定是发行者，此时的下载安装环境已不再是一个相对封闭和安全的环境，因此，

动态加载应用的安全性除了防火墙机制、代码校验机制，还包括下载、安装过程中的安全性。

7.5.2.1 应用代码安全

动态加载应用代码的安全性包括：

1. 被下载代码的正确性、有效性和完整性
2. 下载、安装的安全性
3. 运行时的安全性

7.5.2.1.1 代码校验机制

相对代码运行时，对代码安全性的保证机制而言；在安装之前对代码的检查机制，称之为对代码进行静态分析。静态分析代码的正确性、完整性和有效性，在校验成功后与授权校验数据相关联，多应用金融智能卡对该数据校验成功后才能进行应用的下载安装等操作。

7.5.2.1.2 下载、安装的安全性

动态加载应用代码下载、安装的安全性可以采用如下方式来实现：

1. 根据不同的生命周期阶段，采用不同的安全策略；
2. 采用安全通信机制搭建发送实体与接收实体之间的安全通信环境：
 - 1) 实体认证：卡外实体或者卡外实体与卡内实体通过身份认证，保证进行数据交换的发送实体和/或接收实体为可信任实体。
 - 2) 完整性认证：多应用金融智能卡通过密码学方法保证来自卡外实体的动态下载应用代码确实来自自己认证的卡外实体，且该数据未被做修改、删除、插入等任何篡改。
 - 3) 机密性：卡外实体发送给多应用金融智能卡的动态下载应用代码以密文的方式进行传输的，避免明文传输泄露信息。
3. 根据不同的权限执行不同的合法操作。

7.5.2.1.3 防火墙机制

动态加载应用代码运行时的安全性由应用防火墙机制来保证，详见 7.5.1.1 节“应用代码安全”。

7.5.2.2 应用数据安全

动态加载应用数据的安全性包括：

1. 被下载应用的正确性、有效性和完整性
2. 下载、安装的安全性
3. 运行时的安全性
4. 针对安全敏感数据的安全管理

7.5.2.2.1 代码校验机制

安装之前对代码进行静态分析，即代码校验机制。静态分析代码的正确性、完整性和有效性，在校验成功后与授权校验数据相关联，多应用金融智能卡对该数据校验成功后才能进行应用的下载安装等操作；配合有效完全的防火墙机制才能真正达到应用数据安全隔离，阻止应用数据被非法访问或破坏。

7.5.2.2.2 下载、安装的安全性

动态加载应用数据下载、安装的安全性可以采用如下方式来实现：

1. 根据不同的生命周期阶段，采用不同的安全策略；
2. 采用安全通信机制搭建发送实体与接收实体之间的安全的通信环境：
 - 1) 实体认证：卡外实体或者卡外实体与卡内实体通过身份认证，保证进行数据交换的发送实体和/或接收实体为可信任实体。
 - 2) 完整性认证：多应用金融智能卡通过密码学方法保证来自卡外实体的动态下载应用代码确实来自自己认证的卡外实体，且该数据未被做修改、删除、插入等任何篡改。
 - 3) 机密性：卡外实体发送给多应用金融智能卡的动态下载应用代码以密文的方式进行传输的，避免明文传输泄露信息。
3. 根据不同的权限执行不同的操作。

7.5.2.2.3 防火墙机制

动态加载应用数据运行时的安全性由应用防火墙机制来保证，详见 7.5.2 节“应用数据安全”。

7.5.2.2.4 针对敏感数据的安全管理

动态加载应用数据针对安全敏感数据的安全管理，与预装应用类似，详见 7.5.2 节“应用数据安全”。

8 多应用金融智能卡安全要求

8.1 多应用金融智能卡安全环境

多应用金融智能卡安全环境主要包括：

1. 在开发阶段，所有的开发活动必须是访问可控的、可追踪的；而且在此阶段所有参与人员都充分理解并严格执行规定的安全过程。
2. 在多应用金融智能卡生命周期的各阶段，能对多应用金融智能卡相关资料信息传递及存储过程的安全进行控制：
 - 1) 在传递及存储的过程中，能保证多应用金融智能卡相关资料信息的安全性；
 - 2) 在传递及存储的过程中，当发生不正确的操作时应能保证采取合理的措施；
 - 3) 在传递及存储的过程中，应能保证负责传递的人员具备必要的技能。
3. 在开发阶段、集成电路的生产阶段、智能卡生产阶段以及智能卡发行和个人化阶段，应能保证进行恰当的功能测试；且在所有的生产、测试中都能采取安全的步骤以维护生产测试数据的机密性和完整性（如防止可能的复制、修改、窃取、私自保留或未授权的使用等），其中很重要的还有对废弃数据的彻底处理，如彻底的电子擦除和文档的完全粉碎；另外，应能保证全过程的可追踪。
4. 在智能卡最终用户阶段，能保证在智能卡与终端之间采用安全通信协议及相应步骤；同时提供应用开发指导手册供应用提供商进行后下载应用的开发。

8.2 安全威胁攻击

多应用金融智能卡应能抵御如下安全威胁攻击：

1. 对多应用金融智能卡进行未授权的全部或部分克隆。

2. 在开发阶段，有三类安全威胁攻击需考虑：
 - 1) 对智能卡嵌入式软件及其开发环境的攻击，如对智能卡嵌入式软件和/或初始化数据未授权的发布、修改、窃取或未授权使用等；
 - 2) 当进行嵌入式软件开发时，对从 IC 设计者到软件开发者进行传递的资料信息的攻击；
 - 3) 在资料信息从软件开发者向 IC 设计者传递的过程中，对智能卡嵌入式软件和/或初始化数据的攻击。
3. 在数据从智能卡开发者向 IC 封装厂商、生产厂商或个人化发行者传递的过程中，对数据的攻击，如对预置应用及嵌入式软件私有数据进行未授权的发布、修改等。
4. 在智能卡生产阶段以及智能卡发行和个人化阶段，有三类安全威胁攻击：
 - 1) 对嵌入式软件、预置应用及数据（如数据保护系统、存储区管理、密码程序、密钥等）的未授权发布；
 - 2) 对嵌入式软件、预置应用及数据的窃取或未授权使用，试图访问相关资料信息或执行某些不允许的操作（如攻击者试图通过欺诈获得对智能卡系统的访问，或者可能以未授权的方式对智能卡进行个人化等）；
 - 3) 对安全功能数据的未授权修改或破坏；预置应用的未授权下载或非法修改；多应用金融智能卡平台或应用程序的非法执行；通过不同程序的互操作对平台或应用程序行为的非法修改；对智能卡嵌入式软件及其数据的未授权修改。
5. 与可加载应用相关的安全威胁攻击：
 - 1) 未经许可将应用加载至多应用金融智能卡上，这可能导致卡片资源的非法使用以及未经校验应用对多应用金融智能卡中的其他应用及用户数据的攻击；
 - 2) 一应用伪装成其他可加载应用下载至多应用金融智能卡上，这可能导致对卡片资源和用户数据的攻击；
 - 3) 将一对应特定安全域的可加载应用下载至另一安全域中，这可能导致该应用的安全性降低，从而对应用数据安全造成影响；
 - 4) 没有应用提供者的允许监听应用下载以及改变代码和数据；
 - 5) 监听应用下载并获得对应用机密代码或数据的访问；
 - 6) 加载一个应用以部分或全部重写其他应用，导致其他应用的代码或数据损坏或可被非法访问。
 - 7) 未经许可删除一个已加载应用；
 - 8) 删除一个已加载应用后使得机密的代码和/或数据仍在存储器中可被探测；
 - 9) 删除一个已加载应用同时删除了另一个部分或全部的已加载应用；
 - 10) 用一个可加载应用读取属于另一个已下载应用的机密代码或数据；
 - 11) 未经授权，用一个可加载应用修改属于另一个已下载应用的机密代码或数据；
 - 12) 对卡片资源的破坏。
6. 在智能卡最终用户阶段，对用户数据（包括应用提供者和终端用户）及安全功能数据的未授权发布、未授权修改或破坏。

8.3 安全目标

多应用金融智能卡应能达到如下安全目标，为了达到这些安全目标，若提供了相应的集成电路物理安全特性，则关于这些集成电路物理安全特性的规范也需同时考虑；若未使用相应的集成电路物理安全特性，则需以其它方式来实现如下安全目标。

1. 防止对多应用金融智能卡安全关键部分的篡改。特别是对功能参数、安全属性、生命周期序列标记、加密密钥等，需要安全机制来阻止对其的未授权修改。

2. 嵌入式软件设计必须达到：嵌入式软件不可通过硬件部分的电信号而被解析。
3. 多应用金融智能卡必须被保护不被克隆。
4. 保证安全功能连续的正确操作。
5. 保证嵌入式软件的安全机制不可未经授权进行发布。
6. 保证存放于各类存储器的敏感信息不可未经授权进行发布。
7. 保证存放于各类存储器的敏感信息不可被损坏或未经授权进行修改。
8. 即使之前的下载过程或者删除过程出现了错误，在对一个可加载应用进行下载之前，多应用金融智能卡也应处于一个实现定义好的有效状态下。下载过程或者删除过程出现的错误不能影响多应用金融智能卡的资源，这样的回滚机制可以自动实现也可以通过特定的指令实现。
9. 必须提供一定的方式对用户使用资源做控制，以阻止某一用户未授权的永久占用某些资源导致其他用户因资源不足而被拒绝。如必须阻止一个可加载应用对全部永久存储器（如EEPROM）资源的控制，因为这样会导致其他可加载应用不能使用该资源。
10. 可加载应用只有获得许可才能被下载到多应用金融智能卡上。
11. 如果有需要，应用下载过程必须能够保证机密性、完整性，且能验证可加载应用代码和数据身份合法。
12. 下载一个应用不能对已存在的应用的代码和数据造成影响。
13. 删除一个可加载应用并回收再使用该应用的空间只能在获得许可的情况下才能进行，而且该空间不能留有与该被删除应用的代码和数据相关的任何信息。
14. 删除一个可加载应用不能对剩下的独立应用的代码和数据造成影响。
15. 各可加载应用应相互隔离。一个可加载应用未经授权不可对另一个可加载应用代码和数据进行读写。

8.4 安全要求

8.4.1 安全功能要求

根据上述多应用金融智能卡可能遭受的安全威胁攻击及所应达到的安全目标，本章节定义了相应的安全功能要求。

1. 安全检查告警：
 - 1) 多应用金融智能卡应负责检测潜在的安全威胁。
2. 安全检查分析：
 - 1) 多应用金融智能卡应能采用一套规则来监视被检查的事件，这套规则针对潜在的安全威胁；
3. 加密密钥管理：
 - 1) 加密密钥访问：多应用金融智能卡应能依据特定的密钥访问方法处理不同的加密密钥访问类型，这些特定的密钥访问方法满足所要求的标准规范；
 - 2) 加密密钥销毁：多应用金融智能卡应能依据特定的密钥销毁方法销毁加密密钥，这些特定的密钥销毁方法满足所要求的标准规范。
4. 密码操作：
 - 1) 多应用金融智能卡应能依据特定的密钥算法和密钥长度执行不同密码操作，这

些特定的密钥算法和密钥长度满足所要求的标准规范；

5. 访问控制功能：
 - 1) 多应用金融智能卡应能根据不同的安全属性或者安全属性组强制实行不同的安全策略；
 - 2) 多应用金融智能卡应能根据相应的规则来决定被控制主体与客体之间的操作是否是允许的。
6. 数据鉴权：
 - 1) 多应用金融智能卡应能产生用于验证数据有效性的鉴权值；
 - 2) 多应用金融智能卡应能通过检验鉴权值来验证指定信息的有效性。
7. 残留信息保护：
 - 1) 多应用金融智能卡应保证资源中之前的信息内容不可被泄露。
8. 回滚：
 - 1) 多应用金融智能卡应能针对特定对象的特定操作进行回滚；
 - 2) 多应用金融智能卡应能允许特定操作在特定限定范围进行回滚。
9. 存储数据的完整性：
 - 1) 多应用金融智能卡应能根据用户数据属性监控所存储的用户数据的完整性错误；
 - 2) 一旦检测到数据完整性错误，应采取特定的措施；
10. 认证错误处理：
 - 1) 多应用金融智能卡应能检测到针对特定认证事件的错误尝试次数；
 - 2) 当达到或超过规定的错误尝试次数，多应用金融智能卡应采取特定的措施。
11. 用户认证：
 - 1) 在用户通过认证之前，多应用金融智能卡应允许进行特定的操作；
 - 2) 除上述特定操作之外，多应用金融智能卡应要求用户成功认证之后才可进行其他操作。
 - 3) 多应用金融智能卡应防止特定认证机制的认证数据被重复使用。
12. 安全功能行为的管理：
 - 1) 多应用金融智能卡应将安全功能行为的开启、关闭、修改等严格限制在预先授权确定的角色范围内。
13. 安全属性的管理：
 - 1) 多应用金融智能卡应将安全属性的查询、修改、删除以及其他操作等严格限制在预先授权确定的角色范围内。
 - 2) 多应用金融智能卡应保证只有安全可靠的值才能被接受用作安全属性值。
 - 3) 多应用金融智能卡应提供用于强制执行安全功能策略的缺省值；
 - 4) 当一个对象或者信息被创建时，多应用金融智能卡应允许授权确定的角色定义可替换的初始值来覆盖缺省值。
14. 安全功能数据的管理：
 - 1) 多应用金融智能卡应将安全功能数据的查询、修改、删除、清除以及其他操作等严格限制在预先授权确定的角色范围内。
 - 2) 多应用金融智能卡应将安全功能数据的上下限值严格限制在预先授权确定的角色范围内。
 - 3) 如果安全功能数据达到或者超过指定上下限值，多应用金融智能卡应采取特定的措施。
15. 安全管理角色：

- 1) 多应用金融智能卡应维护授权确定角色的管理;
- 2) 多应用金融智能卡应能将授权确定角色与用户关联。
- 16. 不可观测性:
 - 1) 多应用金融智能卡应保证用户和/或主体无法观测到受保护的对象的的操作, 包括机制、使用的用户数据以及用户数据的处理等。
- 17. 发生错误时的安全:
 - 1) 当特定类型的错误发生时, 多应用金融智能卡应能保持一个安全状态。
- 18. 安全功能的物理防护:
 - 1) 多应用金融智能卡应能通过自动应答来抵御对安全功能设备/元件的物理破坏。
- 19. 可信的恢复:
 - 1) 多应用金融智能卡应能保证: 安全功能或者完全执行成功, 或者针对指定的错误场景恢复到一个一致的、安全的状态。
- 20. 安全策略的不可被绕过性:
 - 1) 在每一项安全功能允许执行之前, 多应用金融智能卡应保证安全策略被强制调用且成功执行。
- 21. 域的隔离:
 - 1) 多应用金融智能卡应维护安全域以保护安全域中的应用不受不可信主体的干扰和破坏;
 - 2) 多应用金融智能卡应强制实行各安全域的隔离。
- 22. 资源分配:
 - 1) 多应用金融智能卡应对被控制的资源强制实行最大配额的限制, 使得单个用户、用户群组等同时或者在某段特定时间内所占用的资源被限制在一定范围内。

8.4.2 芯片安全要求

加载多应用的智能卡需要满足: 芯片必须符合所有卡内应用对应芯片安全规范的最高要求。如: 应用 A 规范中要求应用使用 EEPROM 作为数据的存储介质, 应用 B 规范中允许应用使用 EEPROM 或 FLASH 作为数据的存储介质, 则同时加载应用 A 和应用 B 的智能卡必须使用 EEPROM 作为应用存储的介质。

芯片安全要求详见《中国银联移动支付技术规范》第 2 卷第 2 部分 6.1 节。或银联卡芯片安全规范。

8.4.3 COS 安全要求

COS 安全要求详见《中国银联移动支付技术规范》第 2 卷第 2 部分 6.2 节。

加载多应用的智能卡需要分别满足各应用在其环境下的安全要求, 包括加密算法、个人化等。

一个应用一旦被创建, 该应用可以被安全的删除。拥有权限的主体才可执行应用删除操作, 拥有权限的主体包括卡片发行机构以及通过卡片发行机构进行授权或是委托的被授权机构和代理机构。

MF 作为智能卡的根, 拥有卡片的主控密钥。卡片的主控密钥可用于控制创建应用环境和装载应用环境的主控密钥。在多应用的卡中, 卡片主控在创建完成应用环境的主控密钥后, 立即失去对应用的控制权。后续应用中密钥的加载、更新和应用中文件以及 ADF 的创建由

应用环境下主控密钥控制。

8.4.4 多应用金融智能卡安全防护要求

智能卡内加载多应用需要满足：“应用项目隔离，互不影响”的安全原则。

具体来说，在智能卡内加载的数个应用之间均存在防火墙，在某一应用中的任何操作（包括卡片锁定），都不应影响到卡内其他应用的数据，和其他应用的现有状态。在某一应用内，使用其他应用内的密钥操作本应用内数据都视为非法。

多应用金融智能卡应用级别的安全要求详见《中国银联移动支付技术规范》第2卷第2部分6.3节

多应用金融智能卡用户级别的安全要求详见《中国银联移动支付技术规范》第2卷第2部分6.4节

中国银联
版权所有